# ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

**Schneider Electric PowerLogic PM5560 Power Meter (PM5500 series)** · Component type: **Embedded Device (EDR) - power meter** · Target SL = SL 3

| | |
|---|---|
| **Identity / scope** | **PowerLogic PM5560** (PM5500 series) panel power meter: display, two-port 10/100 Ethernet switch (one IP), RS-485, Modbus gateway. PM5563 and PM5580 follow the same firmware columns. Two firmware generations behave differently - read the version first (Maint › Diag › Info): **[2.x]** = 2.9.9 or earlier (legacy webpages, HTTP only), **[4.x]** = 4.0.0 or later (new webpages, HTTPS, roles). Rows mark 2.x or 4.x where they differ. |
| **Where to work** | Webpages: 4.x `https://<meter>`, 2.x `http://<meter>`. Display: Maint › Setup (setup passcode) for Comm, HMI › Pass; Maint › Diag › Info; Maint › Resets. Tools named in the manual: ION Setup, Firmware Upgrade Tool (PM5000fwupgrade.exe), PM5kDataLogger. |
| **Ports (manual)** | Modbus TCP **502** (32 connections), HTTP **80** and HTTPS **443** (3 per IP), FTP 21 / data 20, FTPS 990 / 989, DHCP/BOOTP 67, BACnet/IP **47808**, EtherNet/IP **44818** (32), DNP3 **20000** (3 sessions), SNTP 123, SNMP **161** (traps 162), SMTP 25; 128 TCP connections shared. EtherNet/IP, BACnet/IP and DNP3 are not supported over IPv6. |
| **Defaults (manual)** | Enabled: Modbus TCP, EtherNet/IP, BACnet/IP, **SNMP** (communities **public** / **private**), HTTP/HTTPS, IPv4, IPv6 (4.5.0+), configuration by display, webpages and **Modbus programming**. Disabled: FTP/FTPS, SNTP, SMTP, DNP3, time sync, Modbus IP filtering (so every IP has full Modbus access). Display passcodes default **0** (Setup, Energy, Demand, Min/Max and User Acc resets). **[2.x]** web/FTP **user1/pass1** (Web Master), **user2/pass2** (Product Master); **2.7.8 to 2.9.9: HTTP accessible without credentials** (webpages with limitations). **[4.x] Administrator** / meter MAC address (change forced at first login), **Guest** / **Powerlogic@1** (change recommended, not forced); passwords 8-16 with number, capital and special; session timeout 10 min; self-signed certificate, TLS 1.2. |
| **Advisories** | **SEVD-2021-159-02** / CISA **ICSA-24-331-01**: CVE-2021-22763 (weak password recovery, admin access, CVSS 3.1 8.1) and CVE-2021-22764 (crafted HTTP request causes loss of Modbus TCP connectivity, 5.3) - PM5560 before 2.7.8, fixed 2.8.3; mitigation block or disable HTTP. CVE-2018-7795 (stored XSS, older firmware). Recheck Schneider SEVD and CISA at each assessment. No IEC 62443 certificate found. |
| **How to read** | Each row: the webpage or display path, the read-only check, then the V&V evidence. Login, lockout and session tests only on a lab or spare meter with written authorization. The meter feeds billing and energy data; resets, Modbus writes and firmware changes alter or erase that data. Where a page does not need Administrator, view it with the read-only Guest role (**[4.x]**). |

## Project / config capture & evidence handling - capture the device backup + config export

**Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own.** Capture the device's own backup / project export so nothing is missed:
**1. Pull the native backup / project + full config export first** (read-only, before anything): **webpage screenshots** taken with a site Administrator (4.x) or Product Master (2.x) account, view only: Home › Device Identification (4.x) or Diagnostics › Meter Information (2.x); Settings › User Management › User Accounts (4.x) or Settings › User Accounts (2.x); Warning Banner; Security › Product Certificate; every Settings › Communication › page (Ethernet Settings, Advanced Ethernet Settings, Date Time Settings, IP Filtering, DPWS, SNMP, DNP3, EtherNet/IP, BACnet/IP, Email On Alarm, Device Log Export, Serial Port); Maintenance › Maintenance Log (all pages with Next 10 Records) and Upgrade › Upgrade Status. Photos of the display Maint › Diag › Info (model, serial, firmware, OS CRC) and Maint › Diag › Cl Pwr, and of the meter label, seals and cabinet (take Ethernet values from the webpages, not from display setup mode). The site's ION Setup or Firmware Upgrade Tool records if they exist (the tool's Config.csv holds passwords in clear - record that it exists, do not copy it). **Never** press Save changes, Apply Changes, Default, Add User, terminate sessions, create a certificate, Upgrade, Test HTTP or Manual Export (Device Log Export), any reset (Maint › Resets, including User Acc Resets), or enable FTP, and do not write Modbus, BACnet, DNP3 or EtherNet/IP values (including CIP Reset or Set services).
**2. Export the security-relevant settings:** user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
**3. Collect firmware & logs:** firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
**4. Capture the device identity:** nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
**5. Name + protect (keep everything):** `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
**6. Then analyze offsite** against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

## FR 1 — Identification & Authentication Control (IAC)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 1.1** | Human user identification & authentication | **[4.x]** webpages need a username and password; change of the Administrator default is forced at first login. **[2.x]** webpages and FTP use user1/user2 accounts; **firmware 2.7.8 to 2.9.9 serves HTTP without credentials** - record as Fail and plan the 4.x upgrade. Display: setup and reset screens need a passcode (default 0).<br>**Test:** open the webpage in a new browser session -> login page before any data (4.x).<br>**V&V evidence:** login page screenshot; firmware version photo. | Every interface authenticates; no 2.7.8-2.9.9 HTTP-without-login exposure. | 2.x limitation. |
| **SR/CR 1.2** | Software process & device identification & authentication | Modbus TCP, BACnet/IP, EtherNet/IP and DNP3 clients are not authenticated by the meter. Compensating: Modbus TCP/IP filtering (up to 10 IPs, Read-only / Full / None) and network zoning. Record the device name (factory PM55-#serial) and Modbus unit ID.<br>**V&V evidence:** Settings › Communication › IP Filtering screenshot; zone drawing. | Only approved hosts reach industrial protocols. | Partial - compensating. |
| **SR/CR 1.3** | Account management | **[4.x]** Settings › User Management › User Accounts: Administrator, Guest and up to 4 more users (6 total); roles Administrator or Guest. **[2.x]** Settings › User Accounts (Product Master only): groups Web User, Web Master, Product Master; user 1 must be Web Master and user 2 Product Master. Confirm named accounts, Guest changed or unused, no shared logins.<br>**V&V evidence:** user account page screenshot; site account register. | Named accounts; least privilege; unused accounts removed. | |
| **SR/CR 1.4** | Identifier management | **[4.x]** usernames 1-15 characters, case sensitive. Confirm the two built-in names (Administrator, Guest) are tied to named people by procedure, since they cannot be renamed in the manual's procedure.<br>**V&V evidence:** account list; register. | Every identifier traceable to a person. | |
| **SR/CR 1.5** | Authenticator management | Confirm all defaults changed: 4.x Administrator (MAC-based, forced change) and **Guest Powerlogic@1** (not forced); 2.x **pass1/pass2**; display passcodes default **0** (Maint › Setup › HMI › Pass). Ask the site - do not try defaults on a live meter. Manual recommends changing passwords every three months. The Firmware Upgrade Tool Config.csv stores the Web Master and Product Master passwords in clear - confirm it is deleted or protected.<br>**Test:** (lab) log in once as Administrator with the default -> change forced.<br>**V&V evidence:** administrator statement; change record. | No default passwords or passcodes in use; tool files protected. | |
| **SR 1.6** | Wireless access management | The PM5560 has no wireless interface. Record as not applicable.<br>**V&V evidence:** photo of meter ports. | N/A - no wireless. | N/A - justification. |
| **SR/CR 1.7** | Strength of password-based authentication | **[4.x]** 8-16 characters with at least one number, capital and special character; no history or ageing setting described. **[2.x]** only a strength indicator (weak to very strong), no enforced rule. Display passcodes are 4 digits. Record gaps against the site SL-3 policy.<br>**V&V evidence:** password rule note; firmware version. | Password rules meet site policy, or gap recorded. | Partial expected. |
| **SR/CR 1.8** | Public key infrastructure (PKI) certificates | **[4.x]** Settings › Security › Product Certificate shows the certificate; the manual says only a self-signed Schneider certificate is configured. Record issuer, validity and key; record that a site CA certificate cannot be loaded per the manual. **[2.x]** no HTTPS.<br>**V&V evidence:** certificate screenshot.<br>**Ext. tools:** `nmap -Pn -p 443 --script ssl-cert <meter>` | Certificate known and trusted by procedure, or gap recorded. | Partial - self-signed only. |
| **SR/CR 1.9** | Strength of public key-based authentication | The meter does not authenticate clients by certificate. Record as not supported; compensate with IP filtering and zoning.<br>**V&V evidence:** note. | Not supported - compensated. | Partial - compensating. |
| **SR/CR 1.10** | Authenticator feedback | Webpage passwords are masked; check a failed login gives a generic message.<br>**Test:** (lab) wrong password with a test account -> no hint which field failed.<br>**V&V evidence:** screenshot. | Masked entry; generic failure. | |
| **SR/CR 1.11** | Unsuccessful login attempts | The manual does not describe a lockout after failed logins for 4.x or 2.x. Record as not documented; verify on a lab meter; compensate with IP filtering, HTTPS only from an engineering subnet and monitoring.<br>**Test:** (lab only, test account) repeated wrong passwords -> record whether anything locks or slows.<br>**V&V evidence:** lab result. | Lockout present, or gap recorded with compensating controls. | Not documented. |

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 1.12** | System use notification | **[4.x]** Settings › User Management › Warning Banner (up to 450 characters, per language; default text is a copyright notice). Confirm the site notice is set. **[2.x]** no banner.<br>**V&V evidence:** login page screenshot. | Approved notice on the login page (4.x). | |
| **SR 1.13** | Access via untrusted networks | Confirm no meter port is reachable from the Internet or office networks; remote access via the site jump host. SEVD mitigation: block HTTP at the firewall.<br>**V&V evidence:** firewall rules; scan from the untrusted side.<br>**Ext. tools:** `nmap -Pn -sT -p 20,21,80,443,502,989,990,20000,44818 <meter>` from the untrusted side (authorized) | Meter reachable only from the metering zone. | |
| **CR 1.14** | Strength of symmetric key-based authentication | No symmetric-key authentication is described. Record as not used.<br>**V&V evidence:** note. | N/A - not used. | N/A - justification. |

## FR 2 — Use Control (UC)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 2.1** | Authorization enforcement | **[4.x]** Administrator = full read/write; Guest = read only (Home, Monitoring, Diagnostics, Maintenance; no Settings or firmware upgrade). **[2.x]** Web User read only, Web Master changes settings, Product Master also accounts and FTP. Protocol writes (Modbus programming enabled by default) bypass web roles - check IP filtering access levels.<br>**Test:** log in as Guest -> Settings not changeable.<br>**V&V evidence:** role list; IP filtering levels. | Write access limited to named administrators and approved hosts. | |
| **SR/CR 2.2** | Wireless use control | No wireless interface. N/A.<br>**V&V evidence:** none required. | N/A. | N/A - justification. |
| **SR 2.3** | Use control for portable & mobile devices | Engineering laptops with ION Setup or the Firmware Upgrade Tool must be site-managed; the tool package and Config.csv are handled as sensitive. The meter has no USB or memory card.<br>**V&V evidence:** laptop register. | Only managed laptops connect. | |
| **SR/EDR 2.4** | Mobile code | Webpages deliver browser scripts from the meter only; no other mobile code. Confirm browsers used are current.<br>**V&V evidence:** note. | No unapproved mobile code. | EDR-specific. |
| **SR/CR 2.5** | Session lock | **[4.x]** webpage sessions time out after 10 minutes of inactivity. **[2.x]** HTTP Connection Idle Time (Advanced Ethernet Settings) closes idle connections; no login session lock described. The display returns to the summary page.<br>**Test:** (lab) stay idle 10 minutes -> re-login required.<br>**V&V evidence:** lab result; setting screenshot. | Idle web sessions end. | |
| **SR/CR 2.6** | Remote session termination | **[4.x]** Administrators can terminate a user's sessions (Settings › User Management › User Accounts); changing a password ends that user's sessions. Users log out with Logout.<br>**V&V evidence:** page screenshot (do not press terminate). | Administrators can end sessions. | |
| **SR/CR 2.7** | Concurrent session control | HTTP and HTTPS allow 3 connections per IP; DNP3 3 sessions; Modbus TCP 32 (gateway server connections 16-64, Advanced Ethernet Settings). The manual advises limiting concurrent user sessions.<br>**V&V evidence:** Advanced Ethernet Settings screenshot. | Session limits documented and kept low. | |
| **SR/CR 2.8** | Auditable events | The Maintenance Log records meter events, in particular setup changes, with Event Type and Event Cause. Login successes and failures are not described as logged. Read the log via Maintenance › Maintenance Log.<br>**V&V evidence:** maintenance log screenshots. | Setup changes logged; gaps for login events recorded. | Partial. |
| **SR/CR 2.9** | Audit storage capacity | Maintenance log size is not stated. Device log export (4.4.5+) sends metering data logs to the PM5kDataLogger; export of the maintenance log is not described - record it by screenshots.<br>**V&V evidence:** Device Log Export settings screenshot. | Maintenance log recorded before overwrite. | Partial. |

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 2.10** | Response to audit processing failures | No audit-failure response is described. Record as not supported; monitor log export results on the data logger host.<br>**V&V evidence:** note. | Gap recorded; external monitoring. | Not documented. |
| **SR/CR 2.11** | Timestamps | Settings › Communication › Date Time Settings (2.x: Settings › Date/Time Settings): Enable Network Time Synchronization, Poll Interval, Primary and Secondary SNTP server, Last Successful Time Synchronization, time zone offset, DST. Default: time sync disabled.<br>**V&V evidence:** screenshot showing last successful sync. | SNTP from approved servers; recent successful sync. | |
| **SR/CR 2.12** | Non-repudiation | The maintenance log shows what changed and the cause; the user is not described as recorded. Named accounts plus change tickets provide traceability.<br>**V&V evidence:** log extract vs change records. | Changes traceable by procedure. | Partial. |
| **EDR 2.13** | Use of physical diagnostic & test interfaces | Front display with Maint menus (passcode protected) and RS-485. User Acc Resets on the display resets web accounts to factory defaults with the reset passcode (default 0) - a physical path to default credentials. Confirm passcodes changed and the meter is in a locked cabinet or sealed.<br>**V&V evidence:** photos; passcode change record. | Display passcodes changed; meter physically protected. | |

## FR 3 — System Integrity (SI)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 3.1** | Communication integrity | HTTPS (TLS 1.2) only on 4.x. Modbus, BACnet, EtherNet/IP, DNP3, SNMP (cleartext community strings, get and get-next only), HTTP and FTP have no integrity protection. The HTTP Server / HTTPS Server setting on display Maint › Setup › Comm › Enet turns the whole web server on or off; a separate HTTP-off setting on 4.x is not described - block TCP 80 at the boundary. Keep FTP off or use FTPS.<br>**V&V evidence:** scan output; protocol settings.<br>**Ext. tools:** `nmap -Pn -sT -p 20,21,80,443,502,989,990,20000,44818 <meter>`; `nmap -Pn -sU -p 123,161,47808 <meter>` | Cleartext protocols confined to the metering zone. | Partial - compensating. |
| **SR/EDR 3.2** | Protection from malicious code | Firmware upgrade checks compatibility and verifies the digital signature (.sedp file, webpage upgrade). No other malware protection on the meter. Laptop and file hygiene compensate.<br>**V&V evidence:** Upgrade Status screenshot. | Only signed firmware accepted; laptops scanned. | EDR-specific. |
| **SR/CR 3.3** | Security functionality verification | After firmware upgrades the manual says security settings stay the same and should be reviewed. Re-run this sheet after each upgrade.<br>**V&V evidence:** post-upgrade review record. | Security settings reviewed after changes. | |
| **SR/CR 3.4** | Software & information integrity | Record firmware (OS, RS), language version and OS CRC (Maint › Diag › Info or Home / Diagnostics). Compare with the approved version. Configuration is not encrypted at rest (manual).<br>**V&V evidence:** version screenshot. | Firmware matches the approved signed release. | |
| **SR/CR 3.5** | Input validation | Webpages enforce value ranges; CVE-2021-22764 shows crafted HTTP could affect Modbus - fixed 2.8.3. Robustness testing only on an isolated bench meter.<br>**V&V evidence:** firmware version vs advisory. | Fixed firmware; no live robustness tests. | |
| **SR/CR 3.6** | Deterministic output | Digital outputs driven by alarms or Modbus: record their configuration and what they control; record behaviour on control power loss (Maint › Diag › Cl Pwr shows the loss count and last occurrence).<br>**V&V evidence:** I/O configuration screenshot. | Outputs fail to a known state; not used for protection. | |
| **SR/CR 3.7** | Error handling | Diagnostics pages show communication statistics; error messages should not reveal secrets. Record any debug or verbose pages enabled.<br>**V&V evidence:** Diagnostics screenshots. | No sensitive data in errors. | |

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 3.8** | Session integrity | **[4.x]** sessions over HTTPS with timeout; check cookies are Secure. **[2.x]** HTTP sessions in clear.<br>**V&V evidence:** header output.<br>**Ext. tools:** `curl -skI https://<meter>/` | Session tokens protected (4.x). | |
| **SR/CR 3.9** | Protection of audit information | Only Administrators change settings; the manual does not describe deleting the maintenance log. Keep dated screenshots of the log.<br>**V&V evidence:** role check; export setting. | Audit records protected and recorded off the meter. | |
| **EDR 3.10** | Support for updates | Upgrades: 2.x via FTP or the Firmware Upgrade Tool; 4.x via the Firmware Upgrade Tool or webpages (Maintenance › Upgrade). Upgrades from 2.5.x-2.9.9 to 4.x use the tool. Confirm current firmware and a patch plan.<br>**V&V evidence:** version vs latest on se.com. | Supported, current firmware; update process defined. | EDR-specific. |
| **EDR 3.11** | Physical tamper resistance & detection | Panel meter in a switchboard; seals and locked cabinet are the controls. Maint › Diag › Cl Pwr counts control power losses.<br>**V&V evidence:** cabinet and seal photos. | Meter locked or sealed; tampering evident. | EDR-specific. |
| **EDR 3.12** | Provisioning product supplier roots of trust | Firmware signature verification implies a Schneider key in the meter; key handling is not described. Record and ask Schneider.<br>**V&V evidence:** Schneider statement. | Supplier root of trust present. | Ask Schneider. |
| **EDR 3.13** | Provisioning asset owner roots of trust | The manual describes only the self-signed certificate (Product Certificate can regenerate it). No owner CA or key load described.<br>**V&V evidence:** note. | Not supported - gap recorded. | Partial - compensating. |
| **EDR 3.14** | Integrity of the boot process | Boot integrity is not described. Record and ask Schneider.<br>**V&V evidence:** Schneider statement. | Boot integrity check present, or gap recorded. | Ask Schneider. |

## FR 4 — Data Confidentiality (DC)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 4.1** | Information confidentiality | **[4.x]** user accounts and passwords stored with SHA-256 and AES-256; HTTPS in transit; meter data and configuration not encrypted. **[2.x]** HTTP and FTP in clear. SMTP alarm e-mail and device log export over HTTP are cleartext unless SSL is enabled.<br>**V&V evidence:** protocol settings. | Credentials protected; cleartext flows confined. | |
| **SR/CR 4.2** | Information persistence | Follow the manual's secure disposal checklist; reset user accounts before disposal or reuse.<br>**V&V evidence:** disposal record. | Meters sanitized before leaving site. | |
| **SR/CR 4.3** | Use of cryptography | TLS 1.2 (4.x HTTPS, FTPS), SHA-256 / AES-256 for stored credentials. Check ciphers.<br>**V&V evidence:** TLS scan output.<br>**Ext. tools:** `nmap -Pn -p 443 --script ssl-enum-ciphers <meter>` | Current algorithms only. | |

## FR 5 — Restricted Data Flow (RDF)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 5.1** | Network segmentation | Meter in a metering zone; the second Ethernet port is a switch (daisy chain) - check it does not bridge zones. Modbus gateway exposes RS-485 devices on TCP 502.<br>**V&V evidence:** zone drawing; port photos. | Meter and daisy chain inside one zone. | |

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR 5.2** | Zone boundary protection | Firewall at the zone edge allows only the energy system and engineering hosts to 502, 443 and needed ports; IP filtering as a second layer.<br>**V&V evidence:** firewall rules. | Boundary filters traffic to the meter. | N/A in device. |
| **SR 5.3** | General purpose person-to-person communication restrictions | Email On Alarm (SMTP, default disabled) sends alarms by e-mail. Confirm it is off or uses an internal relay only.<br>**V&V evidence:** Email On Alarm screenshot. | No uncontrolled e-mail from the meter. | |
| **SR 5.4** | Application partitioning | Single-purpose meter. Record as not applicable.<br>**V&V evidence:** none required. | N/A. | N/A - justification. |

## FR 6 — Timely Response to Events (TRE)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 6.1** | Audit log accessibility | Maintenance log on the webpages; device log export (4.4.5+) of metering data to the data logger; SNMP traps (default off; a wrong community raises an AuthenticationFailure trap).<br>**V&V evidence:** log screenshots; export config. | Authorized staff can read logs off the meter. | |
| **SR/CR 6.2** | Continuous monitoring | SNMP traps (two receivers), alarm e-mail and the energy system can watch the meter; security events are limited. Use network monitoring for unexpected Modbus writes.<br>**V&V evidence:** monitoring configuration. | Meter and its traffic monitored. | Partial. |

## FR 7 — Resource Availability (RA)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 7.1** | Denial of service protection | Connection limits per protocol; CVE-2021-22764 (Modbus loss via HTTP) fixed 2.8.3. No DoS tests on live meters.<br>**V&V evidence:** firmware version. | Fixed firmware; boundary rate limits. | |
| **SR/CR 7.2** | Resource management | Shared 128 TCP connections; Modbus server connections configurable (Advanced Ethernet Settings). Record values.<br>**V&V evidence:** screenshot. | Limits set to need. | |
| **SR/CR 7.3** | Control system backup | No configuration file export is described in the manual; record settings by screenshots and keep the ION Setup or commissioning record. Data log via ION Setup or device log export.<br>**V&V evidence:** settings record. | Configuration recorded and recoverable. | Partial. |
| **SR/CR 7.4** | Control system recovery & reconstitution | Recovery = re-enter settings from the record; lost user access needs User Acc Resets (display) or return to Schneider.<br>**V&V evidence:** procedure. | Recovery procedure documented. | |
| **SR 7.5** | Emergency power | Control power from the panel or UPS; Maint › Diag › Cl Pwr counts control power losses.<br>**V&V evidence:** power design. | Control power resilient where data is critical. | Infrastructure. |
| **SR/CR 7.6** | Network & security configuration settings | Record all protocol toggles, ports (HTTP, HTTPS, FTP and BACnet ports can be changed - scan the configured ones), IP filtering, SNMP communities (8-16 characters with upper, lower and one of @#$%&), DPWS, FTP state and time settings against the approved baseline. If DHCP or BootP fails the meter uses a default IP starting 85.16 from its MAC.<br>**V&V evidence:** screenshots vs baseline. | Settings match the hardened baseline. | |

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / firmware |
|---|---|---|---|---|
| **SR/CR 7.7** | Least functionality | Disable what is not used: FTP/FTPS (on 2.x it returns to Disabled after 20 minutes idle, power-on or upgrade; from 4.0.0 it stays Enabled once enabled), DPWS, SNMP or change communities, BACnet/IP, EtherNet/IP, DNP3, SMTP, Modbus programming if site practice allows; block HTTP 80 at the boundary; enable Modbus IP filtering.<br>**V&V evidence:** scan; settings.<br>**Ext. tools:** `nmap -Pn -sT -p 20,21,80,443,502,989,990,20000,44818 <meter>`; `nmap -Pn -sU -p 123,161,47808 <meter>` | Only required services enabled. | |
| **SR/CR 7.8** | Control system component inventory | Record model, serial, manufacture date, firmware (OS, RS), language version, OS CRC, MAC and IP per meter.<br>**V&V evidence:** inventory sheet. | Complete inventory. | |

## External Test Tools — how to use

| Tool / method | Verifies | How to use — steps / example | Constraints |
|---|---|---|---|
| **Browser** | Webpages (most rows) | 4.x `https://<meter>`; 2.x `http://<meter>`; site account; view only. | No Save, Apply, Default, Upgrade. |
| **Meter display** | Version, passcodes, Comm (1.1, 2.13, 3.4) | Maint › Diag › Info; Comm › Enet only with site passcode, exit No. | Never Resets. |
| **nmap** | Exposure (1.13, 3.1, 7.7) | `nmap -Pn -sT -p 20,21,80,443,502,989,990,20000,44818 <meter>`; `nmap -Pn -sU -p 123,161,47808 <meter>` | Authorized, low rate. |
| **nmap ssl scripts / curl** | Certificate, TLS, headers (1.8, 3.8, 4.3) | `nmap -p 443 --script ssl-cert,ssl-enum-ciphers <meter>`; `curl -skI https://<meter>/` | Read-only. |
| **Wireshark (SPAN)** | Cleartext flows (3.1, 4.1) | Filter `modbus \|\| bacnet \|\| enip \|\| http \|\| snmp` | Passive. |
| **Schneider documents** | Grounding (all) | HRB1684301-18 user manual; SEVD-2021-159-02; ICSA-24-331-01. | - |

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.